Microsoft Purview for Healthcare

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview for Healthcare (HIPAA/PHI) 5

What you get . . . 5

What this delivers . . . 5

Scope boundary . . . 5

The standard deployment model . . . 6

Outcome . . . 6

1. Solution Overview — Microsoft Purview for Healthcare (HIPAA/PHI) 6

What this delivers . . . 6

The four Purview capabilities, tuned for PHI . . . 6

How it works . . . 7

What you can control . . . 7

Benefits . . . 7

Limitations (be honest with buyers) . . . 7

The standard deployment model . . . 8

2. Requirements Guide — Microsoft Purview for Healthcare (HIPAA/PHI) 8

2.1 Microsoft 365 + Purview/compliance licensing for the PHI controls . . . 8

2.2 Least-privilege Purview roles . . . 8

2.3 In-scope PHI data estate and classification intent . . . 9

2.4 PHI data owners, privacy officer, and a records schedule . . . 9

2.5 Pilot scope (care-team users and, for endpoint DLP, devices) . . . 9

2.6 Clinical continuity / emergency-access plan for label encryption . . . 9

2.7 Audit logging enabled . . . 10

2.8 Change control for enforce-mode and retention changes . . . 10

Checklist . . . 10

Global Requirements — Microsoft Purview Solutions 10

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 11

2. Purview roles (least-privilege) and portal access . . . 11

3. Security & Compliance PowerShell + Graph toolchain . . . 11

4. Data sources & scope in scope . . . 12

5. Compliance, records, privacy & legal stakeholders . . . 12

6. A pilot scope and change control . . . 12

3. Implementation Guide — Microsoft Purview for Healthcare (HIPAA/PHI) 13

Step 1 — Design the PHI label taxonomy (Assess → Design) . . . 13

Step 2 — Create the sensitivity labels . . . 14

Step 3 — Publish the labels with a label policy . . . 14

Step 4 — Configure auto-labeling for PHI (SIMULATION only) . . . 15
Step 5 — Build the DLP policy in AUDIT mode . . . 15
Step 6 — Pilot and tune (the DLP audit gate) . . . 15
Step 7 — Switch DLP to ENFORCE (after the gate) . . . 16
Step 8 — Create retention labels (from your records schedule) . . . 16
Step 9 — Create a retention policy (baseline) . . . 16
Step 10 — (Optional, E5) Reduce PHI exposure to Copilot / AI . . . 17
Step 11 — Validate, then expand . . . 17
5. Testing Guide — Microsoft Purview for Healthcare (HIPAA/PHI) 17
Test 1 — PHI labels published and visible . . . 17
Test 2 — PHI label protection applies (and clinical apps still work) . . . 18
Test 3 — PHI auto-labeling simulation matches . . . 18
Test 4 — DLP is auditing PHI (before the gate) . . . 18
Test 5 — DLP enforces PHI (after the gate) . . . 18
Test 6 — Retention label applied and honored . . . 18
Test 7 — Retention policy scoped . . . 18
Test 8 — PHI coverage report . . . 18
Test 9 — (Optional, E5) PHI exposure to AI reviewed . . . 19
Pass/fail gate . . . 19
6. Troubleshooting Guide — Microsoft Purview for Healthcare (HIPAA/PHI) 19
A. PHI sensitivity labels not appearing for users . . . 19
B. Label encryption breaks a clinical app / blocks care access . . . 20
C. PHI auto-labeling not labeling . . . 20
D. HIPAA DLP is too noisy (false positives) . . . 20
E. HIPAA DLP not blocking after enforce . . . 20
F. Retention disposing too much or nothing . . . 21
G. Retention duration uncertainty (which schedule?) . . . 21
H. Licensing / feature missing . . . 21
I. Diagnostics quick reference . . . 21
J. When to escalate . . . 22
7. Best Practices — Microsoft Purview for Healthcare (HIPAA/PHI) 22
8. Deliverables Summary — Microsoft Purview for Healthcare (HIPAA/PHI) 23
Documentation . . . 23
PowerShell scripts . . . 23
What the buyer receives . . . 24
Scope boundary (restated) . . . 24

Outcome 24
Appendix A — PowerShell Scripts 25

Executive Summary — Microsoft Purview for Healthcare (HIPAA/PHI)

White-label · Purview / Industry (Healthcare)

Healthcare runs on protected health information (PHI), and PHI leaks and retention gaps almost always trace back to the same root: data that is never classified, never protected, and never retained on a defined schedule. Microsoft Purview fixes that — but rolled out generically it confuses clinicians, floods the help desk with Data Loss Prevention (DLP) false positives, and — worst of all — can block legitimate care coordination or break a clinical app. This solution delivers Purview **tuned for a PHI data estate**, on a pilot-first model so patient care is never disrupted.

This is a complete, deploy-it-in-order package for implementing a **Healthcare-tailored Microsoft Purview program** aligned to HIPAA/PHI: a PHI-aware sensitivity-label taxonomy with auto-labeling, DLP built on the built-in **U.S. Health Insurance Act (HIPAA)** template that starts in audit and is tuned before it enforces, and retention/records driven by **your** records schedule. It is written for an administrator with no prior Purview experience.

What you get

- A plain-language Solution Overview of PHI sensitivity labels, auto-labeling, DLP across Microsoft 365 and endpoints, and retention/records — and how they work together for a PHI estate.
- A Requirements Guide with verify / implement-if-missing for every Healthcare/PHI prerequisite — including licensing, least-privilege roles, and a clinical-continuity / emergency-access plan for label encryption.
- An Implementation Guide of precise, ordered steps in the Microsoft Purview portal.
- Five PowerShell scripts for configuration discovery, coverage validation, a PHI classification and DLP-event report, safe remediation of gaps, and a PHI pilot-scope group builder.
- Testing and Troubleshooting guides for a confident, clinician-safe rollout.

What this delivers

A named, reusable set of objects — a PHI sensitivity-label taxonomy, label policies, an auto-labeling policy, a HIPAA DLP policy, and retention labels/policies — deployed on the assess-configure-pilot model with a mandatory DLP audit gate before any policy switches to enforce, and a documented rollback.

Scope boundary

Regulatory, records-retention, and legal determinations — which data is a designated record set, how long medical records must be kept (state law, records schedule), records file plans, legal holds, and insider-risk / communication-compliance case actions — are **deferred to your compliance, records, privacy, and legal functions**. The solution provides the technical method and the evidence, not the determination. Purview features are **licensing-/plan-dependent and evolving — verify your licensing/tenant.**

The standard deployment model

Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand (enforce).

Outcome

PHI classified, protected, and retained with Microsoft Purview — a clear PHI label taxonomy with auto-labeling, HIPAA DLP tuned in audit before it enforces, and retention that meets your records schedule — proven on a pilot before you scale, and defensible in an audit.

1. Solution Overview — Microsoft Purview for Healthcare (HIPAA/PHI)

What this delivers

Healthcare organizations hold **electronic protected health information (ePHI)** — patient records, diagnoses, insurance identifiers, clinical correspondence — under specific obligations (in the U.S., the HIPAA Privacy and Security Rules). This solution configures a **Healthcare-tailored Microsoft Purview program** — sensitivity labels, Data Loss Prevention (DLP), retention/records, and the supporting classification — so PHI is **classified, protected, retained on a defined schedule, and its handling is evidenced**. It is the same Purview toolset, tuned for a PHI data estate and rolled out on a pilot-first model so clinical work is never disrupted.

> ***Scope boundary.*** *This solution provides the **technical configuration method and the evidence** — it does **not** make regulatory, records, or legal determinations. *Which* data is a designated record set, *how long* medical records must be retained (this is set by state law and your records schedule and varies widely — often longer for minors), whether a HIPAA obligation applies, and any legal-hold or insider-risk case action are **deferred to your compliance, records, privacy, and legal functions.** You supply the schedule and the classification intent; the solution implements it.*

The four Purview capabilities, tuned for PHI

1. **Sensitivity labels** — persistent tags (for example `Public`, `Internal`, `Confidential - PHI`, `Highly Confidential - PHI Restricted`) that can encrypt content, apply visual markings, and restrict sharing so PHI stays protected wherever a file travels — inside or outside the tenant.
1. **Data Loss Prevention (DLP)** — policies that detect PHI (for example the built-in **U.S. Health Insurance Act (HIPAA)** template and health-related sensitive information types) and take action — audit, warn, or block — as users share it across Exchange, SharePoint, OneDrive, Teams, and managed endpoints.
1. **Retention and records** — labels and policies that keep PHI-related content for a schedule-defined period and then dispose of it (or block deletion for declared records), so the organization meets its retention obligations without hoarding or over-deleting.
1. **Classification and reporting** — sensitive information types, trainable classifiers, and the

Purview audit / Activity explorer that make PHI coverage visible and reportable.

How it works

1. You design a small PHI-aware label taxonomy and publish it with a label policy so labels appear in Outlook, Word, Excel, and the web. **Auto-labeling** can apply the PHI label automatically based on content (for example content matching the HIPAA sensitive-information types) — always in **simulation** first.

1. DLP policies reference the healthcare sensitive-information types and/or the PHI sensitivity label. Each policy is first deployed in **audit/test mode**; you review the matches (the DLP audit gate), tune out false positives, and only then switch to enforce (warn or block).

1. Retention labels and policies set how long PHI-related content lives and what happens at the end of the period, using **the schedule your records/legal function supplies**. Records management adds declared, immutable records and disposition review.

1. Every action is logged in the Purview audit and Activity explorer, so PHI classification and DLP coverage can be reported and defended.

What you can control

• The label taxonomy, priority order, and the protection each label applies (encryption, PHI markings, sharing restrictions) — scoped so PHI-restricted content follows the **minimum-necessary** principle.

• Where labels are published and whether auto-labeling applies the PHI label by content match.

• DLP scope (Exchange, SharePoint, OneDrive, Teams, endpoint devices), the health/PHI sensitive information types or label a policy matches, and the action (audit, notify, block) plus policy tips.

• Retention duration, trigger, and end-of-life action (delete, retain, or declare a record) — driven by **your** records schedule; records management and disposition review.

Benefits

• **Protection that travels** — a PHI sensitivity label encrypts and marks content so ePHI stays protected outside the tenant, supporting the HIPAA Security Rule's technical-safeguard expectations.

• **Fewer leaks, clinician-safe** — DLP tuned in audit before enforcement blocks real PHI exposure without blocking legitimate care coordination.

• **Defensible retention** — PHI-related content is kept and disposed on a defined schedule you can evidence in an audit.

• **Reportable coverage** — PHI classification and DLP events are visible per service and fleet-wide.

Limitations (be honest with buyers)

• Several capabilities (auto-labeling at rest, endpoint DLP, DSPM/DSPM for AI, insider risk,

communication compliance, advanced records) require **Microsoft 365 E5** or the **E5 Compliance** add-on, and some features are in preview — the Requirements Guide names the licensing; **verify your licensing/tenant**.

• **Encryption can affect clinical and third-party apps.** A label that encrypts content may block legacy EHR integrations, PACS viewers, or apps that do not understand the protection. **Pilot before broad enforcement** and plan emergency-access / continuity-of-care handling with clinical IT.

• **Retention deletion is irreversible** once the period elapses — validate the schedule on a pilot scope, and use disposition review for records so nothing is auto-deleted unreviewed.

• Purview protects PHI **within Microsoft 365 and onboarded endpoints** — PHI in a separate EHR, imaging system, or medical device is out of scope for these controls.

The standard deployment model

> ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate/test)*** *→* ***Validate*** *→* ***Expand (enforce).*** *Design the PHI taxonomy → publish labels → configure auto-labeling in simulation → build DLP in audit and tune (the DLP audit gate) → set retention/records from your schedule → pilot → validate → expand — with explicit pass/fail gates and a documented rollback, and all regulatory/records/legal determinations deferred to the relevant governance functions.*

2. Requirements Guide — Microsoft Purview for Healthcare (HIPAA/PHI)

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-purview.md` — this guide adds the **Healthcare/PHI-specific** prerequisites and does not repeat the six.

2.1 Microsoft 365 + Purview/compliance licensing for the PHI controls

Description: Licensing that includes the capabilities this solution configures. Sensitivity labels, manual DLP, and the built-in **U.S. Health Insurance Act (HIPAA)** DLP template ship in Microsoft 365 **E3 / Business Premium**; **auto-labeling at rest, endpoint DLP, DSPM (and DSPM for AI), insider risk management, communication compliance, and advanced records** require **Microsoft 365 E5** or the **E5 Compliance** add-on. **Why:** The PHI features are plan-gated; auto-labeling at rest and endpoint DLP will not appear without the higher plan. Purview licensing/availability evolves — **verify your licensing/tenant**. **Verify:** Microsoft 365 admin center → **Billing** → **Licenses**; confirm the feature is visible in the Purview portal; run `PHI-Discovery.ps1`. **Implement:** Assign the required plan (E3/Business Premium for labels + HIPAA-template DLP; E5 or the E5 Compliance add-on for auto-labeling at rest, endpoint DLP, DSPM, insider risk, communication compliance, advanced records) **before** starting.

2.2 Least-privilege Purview roles

Description: The operator holds the least-privilege roles to create labels, DLP, and retention — for example **Compliance Administrator** (or **Information Protection Admin** plus **Data Loss Prevention** roles), and **Records Management** for records/file-plan work — in the Purview portal. **Why:** Purview uses

fine-grained role groups; Global Administrator alone is not the least-privilege choice, and PHI-sensitive functions (insider risk, communication compliance) require **strict role separation**. **Verify:** `https://purview.microsoft.com` → **Settings** → **Roles and scopes** → **Role groups**; confirm membership. **Implement:** Add the operator to the least-privilege role group(s). Keep insider-risk and communication-compliance roles separated and restricted (HR/privacy sensitivity).

2.3 In-scope PHI data estate and classification intent

Description: The **workloads that hold ePHI** in scope (Exchange, SharePoint, OneDrive, Teams, onboarded endpoints) and a **PHI classification intent** — what counts as PHI, and which health/PII sensitive-information types apply (for example the **U.S. Health Insurance Act (HIPAA)** template, **ICD-9-CM / ICD-10-CM**, **U.S. Social Security Number**, **Drug Enforcement Agency (DEA) Number**). **Why:** DLP and labels key off the in-scope workloads and the classification scheme; without it the policies match the wrong content. **Verify:** Confirm the in-scope workloads and the PHI sensitive-information-type set with clinical, privacy, and security stakeholders. **Implement:** Define the PHI scope and the sensitive-information-type set before authoring policies (Implementation Step 1). Purview protects PHI **within M365/endpoints only** — PHI in a separate EHR or imaging system is out of scope.

2.4 PHI data owners, privacy officer, and a records schedule

Description: Named business owners — including the **HIPAA Privacy/Security Officer** and **records management** — who decide what is PHI, how PHI-restricted content is scoped (**minimum-necessary**), and **how long** each record type is retained. **Why:** Retention durations and DLP conditions are **compliance/records decisions, not IT defaults**. Medical-record retention is set by **state law and your records schedule** (often longer for minors); the technical config must implement that schedule, not guess it. **Verify:** A named Privacy/Security Officer and records owner exist; a **records retention schedule** (source document) is available per record type. **Implement:** Identify the owners; obtain the retention schedule and the PHI classification decision before configuring. **Determinations are deferred to these functions** — the solution implements them.

2.5 Pilot scope (care-team users and, for endpoint DLP, devices)

Description: A Microsoft Entra security group of **pilot users** (a representative clinical/admin ring) for label/DLP/retention piloting, and — for endpoint DLP — clinical/admin **devices onboarded** to Microsoft Purview. **Why:** Every policy is piloted before rollout; DLP in particular must run in **audit** on a pilot before it can enforce safely, so PHI protection never blocks patient care unexpectedly. **Verify:** Entra → **Groups**; the pilot group `Purview - PHI Pilot Users` exists. Purview → **Settings** → **Device onboarding** shows pilot devices onboarded (endpoint DLP only). **Implement:** Build the pilot group with `PHI-Set-ScopeTargeting.ps1`; onboard pilot devices via the Purview device onboarding package.

2.6 Clinical continuity / emergency-access plan for label encryption

Description: A plan, agreed with clinical IT, for how **label encryption** interacts with clinical apps, EHR/PACS integrations, and **emergency ("break-glass") access** to PHI. **Why:** A label that encrypts PHI can block legacy or third-party clinical apps and must never impede **continuity of care**; this risk is specific to healthcare and must be piloted deliberately. **Verify:** A documented list of clinical apps/integrations that touch labeled content, and an emergency-access approach, exists and has been reviewed with clinical IT. **Implement:** Inventory the clinical apps, test encryption against them on the pilot, and agree the

emergency-access handling before enforcing encryption broadly.

2.7 Audit logging enabled

Description: Microsoft Purview audit (unified audit log) is turned on. **Why:** DLP tuning, PHI-coverage reporting, and evidence for HIPAA documentation all read audit/activity data; without it you cannot review the audit gate or report coverage. **Verify:** Purview → **Audit**; a search returns results. Run `PHI-Report.ps1`. **Implement:** Turn on auditing in the Purview **Audit** solution; allow time for events to populate.

2.8 Change control for enforce-mode and retention changes

Description: A documented change-control / rollback process for switching any DLP policy from audit to enforce, or for activating a retention policy that disposes of PHI content. **Why:** Enforce-mode DLP can block clinician work and retention disposal is irreversible; a pilot gate and rollback are mandatory. **Verify:** A change ticket exists with an approver, a pilot scope, and a documented rollback (revert DLP to audit; disable the retention policy). **Implement:** Record the change, name the pilot scope, define the rollback, and get approval before enforcing.

Checklist

- Microsoft 365 + Purview/compliance licensing for the PHI controls (E3 for labels + HIPAA-template DLP; E5/add-on for auto-label at rest, endpoint DLP, DSPM, insider risk, comms compliance) — `PHI-Discovery.ps1` · **verify your licensing/tenant**
- Least-privilege Purview roles assigned (Compliance Admin / Information Protection + DLP; Records Management; separated insider-risk/comms-compliance roles)
- In-scope PHI workloads + health sensitive-information-type set defined
- PHI data owners + Privacy/Security Officer named; **records retention schedule** obtained (determinations deferred)
- Pilot scope group `Purview - PHI Pilot Users` created — `PHI-Set-ScopeTargeting.ps1`
- Endpoint devices onboarded (endpoint DLP only) — `PHI-Discovery.ps1`
- Clinical continuity / emergency-access plan for label encryption reviewed with clinical IT
- Purview audit logging enabled — `PHI-Report.ps1`
- Change control + rollback for enforce-mode / retention disposal

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

Vendor boundary (applies to every Purview solution). *The* ***Microsoft Purview portal*** *(purview.microsoft.com), the* ***Microsoft 365 admin center****,* ***Security & Compliance PowerShell*** *(`Connect-IPPSSession`), and* ***Microsoft Graph*** *are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily* ***licensing-/plan-dependent*** *(many require* ***Microsoft 365 E5*** *or the* ***E5 Compliance*** *add-on; some are in preview) and the portal is* ***actively evolving*** *— capability availability and portal paths are* ***cited or flagged "verify your licensing/tenant"****, never asserted or invented.* ***Regulatory, records-retention, and legal determinations*** *(retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are* ***deferred to the organization's compliance, records, privacy, and legal functions*** *— the solutions provide the technical configuration method and evidence, not the determination. Automation is* ***PowerShell*** *(Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

• **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.

- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.
- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.
- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal** stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).
- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.
- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.
- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.
- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.
- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview for Healthcare (HIPAA/PHI)

Follow these steps **in order**, in the **Microsoft Purview portal** (`https://purview.microsoft.com`). Portal paths are current at authoring time but Purview evolves — if a menu differs, **verify against Microsoft's documentation and your tenant**.

> ***Model:*** *Design a small PHI taxonomy, publish it, add auto-labeling **in simulation**, build DLP in **audit** and tune it (the DLP audit gate) before enforcing, then set retention/records **from your records schedule** — piloting each on* `Purview - PHI Pilot Users` *before you expand. Pattern: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce).***
> *Regulatory/records/legal determinations are **deferred** — you implement the schedule and classification your compliance/records/privacy/legal functions supply.*

The named objects created below are reused verbatim in Testing, Troubleshooting, and the scripts:

Object	Name
Sensitivity labels	`Sensitivity Label - Public - All Users`, `Sensitivity Label - Internal - All Users`, `Sensitivity Label - Confidential - PHI - All Users`, `Sensitivity Label - Highly Confidential - PHI Restricted - All Users`
Label policy	`Label Policy - Healthcare PHI Taxonomy - All Users`
Auto-labeling policy	`Auto-Label - PHI Health Records - Pilot`
DLP policy	`DLP Policy - PHI HIPAA - Audit` (renamed to `... - Enforce` at the gate)
Retention label	`Retention Label - HIPAA Documentation - 6 Year`
Retention label (clinical)	`Retention Label - Medical Records - Schedule-Defined`
Retention policy	`Retention Policy - Healthcare Baseline - Schedule-Defined`

Step 1 — Design the PHI label taxonomy (Assess → Design)

1. With the Privacy/Security Officer and data owners, agree a **small** taxonomy and the protection each label applies. A common healthcare starting set:

• `Sensitivity Label - Public - All Users` — no protection; shareable externally (patient education, marketing).

• `Sensitivity Label - Internal - All Users` — internal business data; no encryption.

• `Sensitivity Label - Confidential - PHI - All Users` — **encrypt**; restrict to the organization;

apply a PHI marking.

• `Sensitivity Label - Highly Confidential - PHI Restricted - All Users` — **encrypt**; restrict to

a **named care-team / role group** per the **minimum-necessary** principle.

1. Record each label's meaning, protection, and who applies it (the one-pager from Requirement 2.4).

Decide, with clinical IT, how encryption interacts with clinical apps and emergency access (Requirement 2.6) **before** enabling encryption.

Step 2 — Create the sensitivity labels

1. Purview portal → **Information Protection** → **Sensitivity labels** → **Create a label**.

2. **Name and tooltip:** enter `Sensitivity Label - Confidential - PHI - All Users` and a clear

user-facing tooltip (for example "Protected health information — do not share outside the organization"). **Next**.

1. **Scope:** select **Items** (files and emails). **Next**.

2. **Encryption:** choose **Configure encryption** for the two PHI labels; set permissions (for

example **All Users in <org>** for `Confidential - PHI`, and a **named care-team group** for `Highly Confidential - PHI Restricted`). Leave `Public` / `Internal` without encryption. **Next**.

1. **Content marking:** add a header/footer/watermark for the PHI labels (for example `PHI — CONFIDENTIAL`). **Next**.

1. **Auto-labeling for items:** leave off here (configured centrally in Step 4). **Next → Create the label**.

1. Repeat for each label in sensitivity order (`Public` → `Internal` → `Confidential - PHI` → `Highly Confidential - PHI Restricted`). Label order sets priority.

Step 3 — Publish the labels with a label policy

1. Purview portal → **Information Protection** → **Sensitivity labels** → **Label policies** → **Publish labels**.

2. **Choose labels to publish:** add all four taxonomy labels. **Next**.

3. **Assign to users and groups:** add `Purview - PHI Pilot Users` for the pilot. **Next**.

4. **Policy settings:** optionally require a justification for downgrading a label and require a label

for new items. **Next**.

1. **Default label / mandatory labeling:** set a default (for example `Internal`) if the org wants one. **Next**.

1. **Name:** `Label Policy - Healthcare PHI Taxonomy - All Users`. **Next** → **Submit**.

Step 4 — Configure auto-labeling for PHI (SIMULATION only)

1. Purview portal → **Information Protection** → **Auto-labeling** → **Create auto-labeling policy**.
2. **Choose the information to label:** pick the **Medical and health** category / **U.S. Health Insurance Act (HIPAA) **template, or** Custom**.** Next**.

1. **Name:** `Auto-Label - PHI Health Records - Pilot`. **Next**.
2. **Admin units / locations:** select **Exchange email**, **SharePoint sites**, **OneDrive accounts **as needed; scope to pilot locations.** Next**.

1. **Rules:** define the condition using the health/PHI sensitive-information types (for example the HIPAA template, **ICD-9-CM / ICD-10-CM**, **U.S. Social Security Number**) and set the label to apply to `Sensitivity Label - Confidential - PHI - All Users`. **Next**.

1. **Simulate first:** choose **Run policy in simulation mode** — **do not turn it on**. **Next → Create**. Review the simulation matches (Testing Test 3) before ever turning the policy on. *Pass/fail:* the simulation must show it matches real PHI and not routine content before you expand.

Step 5 — Build the DLP policy in AUDIT mode

1. Purview portal → **Data Loss Prevention** → **Policies** → **Create policy**.
2. **Category / template:** choose **Medical and health records** → **U.S. Health Insurance Act (HIPAA)** (or **Custom**). **Next**.

1. **Name:** `DLP Policy - PHI HIPAA - Audit`. **Next**.
2. **Locations:** enable **Exchange email**, **SharePoint sites**, **OneDrive accounts**, **Teams chat and channel messages**, and** Devices **(endpoint DLP) as licensed. Scope to** `Purview - PHI Pilot Users` **where the location supports user scoping.** Next**.

1. **Rules:** add a rule matching the PHI sensitive-information types (the HIPAA set) and/or the label `Sensitivity Label - Confidential - PHI - All Users`. Set actions to **audit only** — enable **policy tips** for visibility but do **not** block. **Next**.

1. **Policy mode:** select **Run the policy in test mode** (with policy tips). **Next** → **Submit**. The policy now audits PHI sharing without blocking clinical work.

Step 6 — Pilot and tune (the DLP audit gate)

1. Let the audit-mode policy run against `Purview - PHI Pilot Users` for the agreed window.
2. Review matches in Purview → **Data Loss Prevention** → **Alerts** and **Activity explorer**; run `PHI-Report.ps1` for a PHI classification + DLP-event summary.

1. Tune the rules to remove false positives (adjust confidence levels, instance counts, exceptions —

for example legitimate referral or billing flows).

1. **Gate:** only when the audit shows the policy matches real PHI exposure and not routine care

coordination do you proceed to enforce (Step 7). If it is still noisy, keep tuning — **do not enforce**. Blocking clinicians erroneously is a patient-care risk.

Step 7 — Switch DLP to ENFORCE (after the gate)

1. Purview portal → **Data Loss Prevention** → **Policies** → open `DLP Policy - PHI HIPAA - Audit` →

Edit.

1. Rename it to `DLP Policy - PHI HIPAA - Enforce` so the stage is visible.

2. **Rules:** change the action from audit to **Block** (or **Block with override** so clinicians can

proceed with a business justification) as the business requires; keep policy tips on. **Next**.

1. **Policy mode:** select **Turn the policy on**. **Next** → **Submit**. Enforcement applies to the pilot

scope first; widen it in Step 11.

1. **Rollback (if needed):** set the policy mode back to **Test mode** (audit) or turn the policy off.

Step 8 — Create retention labels (from your records schedule)

1. Purview portal → **Data Lifecycle Management** → **Retention labels** → **Create a label**.

2. **HIPAA documentation label:** `Retention Label - HIPAA Documentation - 6 Year`. HIPAA §164.316(b)

requires required policies/documentation to be retained **6 years** from creation or last effective date; set **Retain items for** 6 years then choose the end action (**Delete** or **Mark as a record**). **Next** → **Create**.

1. **Clinical-records label:** `Retention Label - Medical Records - Schedule-Defined`. **Set the

duration from your records schedule / state law — do NOT guess **(medical-record retention varies by state and is often longer for minors; this is a** records/legal determination**, deferred). Choose** Mark as a record **with** disposition review **for immutable clinical records.** Next → Create**.

Step 9 — Create a retention policy (baseline)

1. Purview portal → **Data Lifecycle Management** → **Retention policies** → **New retention policy**.

2. **Name:** `Retention Policy - Healthcare Baseline - Schedule-Defined`. **Next**.

3. **Locations:** enable **Exchange mailboxes**, **SharePoint sites**, **OneDrive accounts**, and

Teams as required. Scope to `Purview - PHI Pilot Users` for the pilot. **Next**.

1. **Retention settings:** set the duration and end action **from your records schedule** (not a

default). **Next** → **Submit**.

1. For regulatory records, configure **Records Management** → **File plan** to publish the record labels

and set **disposition review** so PHI is reviewed, not auto-deleted. The **file plan and schedule are a records/legal determination — deferred**; you publish what they define.

Step 10 — (Optional, E5) Reduce PHI exposure to Copilot / AI

1. If licensed for **DSPM / DSPM for AI**, review Purview → **DSPM for AI** to see where PHI-labeled

content is exposed to Microsoft 365 Copilot and other AI. **Verify your licensing/tenant** — availability and portal paths evolve.

1. Use the PHI-restricted label and its encryption/permissions to keep restricted PHI out of AI

grounding per the minimum-necessary principle. Pilot before broad enforcement.

Step 11 — Validate, then expand

1. Complete the Testing Guide against `Purview - PHI Pilot Users`.
2. Run `PHI-Validation.ps1` (labels published, DLP present, retention present) and `PHI-Report.ps1`

(PHI classification + DLP-event coverage).

1. Widen scope: republish `Label Policy - Healthcare PHI Taxonomy - All Users`, the DLP enforce

policy, and the retention policy from `Purview - PHI Pilot Users` to broader groups (or **All users** / **All locations**) once the pilot passes. Turn auto-labeling on (out of simulation) only after its simulation is clean and clinical-app/encryption testing (Requirement 2.6) passes.

1. Re-validate each expansion with `PHI-Validation.ps1` and `PHI-Report.ps1`.

Order of operations

`PHI taxonomy → labels → label policy → auto-labeling (simulation) → DLP (audit) → audit gate → DLP (enforce) → retention labels/records (from schedule) → (E5) DSPM for AI → validate → expand`

5. Testing Guide — Microsoft Purview for Healthcare (HIPAA/PHI)

Run after publishing to `Purview - PHI Pilot Users` (Implementation Step 3 onward), before the DLP audit gate (Step 6), and again after each expansion. Use **fake / synthetic PHI** for all tests — never real patient data.

Test 1 — PHI labels published and visible

Do: In Outlook / Word (web or desktop) as a pilot user, open the **Sensitivity** button. Or run `PHI-Validation.ps1`. **Expected:** All four taxonomy labels appear (`Sensitivity Label - Public - All Users` through `Sensitivity Label - Highly Confidential - PHI Restricted - All Users`) via `Label Policy - Healthcare PHI Taxonomy - All Users`.

Test 2 — PHI label protection applies (and clinical apps still work)

Do: Apply `Sensitivity Label - Confidential - PHI - All Users` to a test document and try to open it as an out-of-scope external user. Also open a labeled file in the **clinical apps inventoried in Requirement 2.6**. **Expected:** The document is encrypted/marked; the external user is denied per the label's permissions; and the inventoried clinical apps open it (or the incompatibility is documented for the emergency-access plan **before** enforcement).

Test 3 — PHI auto-labeling simulation matches

Do: Purview → **Information Protection** → **Auto-labeling** → open `Auto-Label - PHI Health Records - Pilot` → **Simulation**. **Expected:** The simulation lists items that match the PHI rule (for example files containing the HIPAA / ICD sensitive information types) — and does not flag routine, non-PHI content. The policy is still in simulation (nothing applied yet).

Test 4 — DLP is auditing PHI (before the gate)

Do: As a pilot user, email a test message containing **synthetic** PHI (for example a fake health identifier / ICD code) to an external address; check Purview → **Data Loss Prevention** → **Alerts** and **Activity explorer**. Or run `PHI-Report.ps1`. **Expected:** `DLP Policy - PHI HIPAA - Audit` records the match (policy tip shown, no block) — the audit gate has data to review.

Test 5 — DLP enforces PHI (after the gate)

Do: After Step 7, repeat Test 4 against `DLP Policy - PHI HIPAA - Enforce`. **Expected:** The action now blocks (or blocks-with-override) per the enforce rule; the event is logged. A clinician can proceed via justification if block-with-override was chosen.

Test 6 — Retention label applied and honored

Do: Apply `Retention Label - HIPAA Documentation - 6 Year` (and, separately, `Retention Label - Medical Records - Schedule-Defined`) to a test item and attempt to delete it. **Expected:** The item is retained for the schedule-defined period (or declared a record and blocked from deletion) per the label; records route to disposition review rather than auto-deleting.

Test 7 — Retention policy scoped

Do: Confirm `Retention Policy - Healthcare Baseline - Schedule-Defined` is applied to the pilot locations (Purview → **Data Lifecycle Management** → **Retention policies** → open the policy). Or run `PHI-Validation.ps1`. **Expected:** The policy shows **On** and scoped to the pilot mailboxes/sites/OneDrive/Teams.

Test 8 — PHI coverage report

Do: Run `PHI-Report.ps1`. **Expected:** A summary of PHI classification (labeled items) and DLP events across the enabled services, so coverage and gaps are visible for the HIPAA evidence record.

Test 9 — (Optional, E5) PHI exposure to AI reviewed

Do: If licensed, Purview → **DSPM for AI** → review PHI-labeled content exposed to Copilot/AI. **Expected:** Restricted PHI is protected by the `Highly Confidential - PHI Restricted` label and its permissions; exposure is understood before broad AI enablement. **Verify your licensing/tenant.**

Pass/fail gate

Gate	Requirement
Pilot pass	Tests 1–4, 6–7 pass on `Purview - PHI Pilot Users`; the DLP audit shows real PHI matches and acceptable noise; clinical-app/encryption compatibility (Test 2) is confirmed or documented
Audit gate	DLP audit reviewed and tuned; only then is Test 5 (enforce) run
Expand pass	Tests 1, 4/5, 7, 8 pass after widening scope beyond the pilot

6. Troubleshooting Guide — Microsoft Purview for Healthcare (HIPAA/PHI)

Use `PHI-Discovery.ps1` for the tenant's current config, `PHI-Validation.ps1` to confirm the named objects are in place, `PHI-Report.ps1` for PHI classification and DLP-event coverage, and `PHI-Remediation.ps1` (default `-WhatIf`) for safe fixes. Purview is licensing-dependent and evolving — if a feature or portal path is missing, **verify your licensing/tenant** before assuming a defect.

A. PHI sensitivity labels not appearing for users

Symptom	Cause	Remediation
No Sensitivity button / PHI labels missing	Label policy not published to the user, or publish still propagating	Confirm the user is in `Purview - PHI Pilot Users`; verify `Label Policy - Healthcare PHI Taxonomy - All Users` targets them; allow up to 24 hours to propagate
Labels appear but no encryption	Label scoped to items but encryption not configured	Edit the label (`Sensitivity Label - Confidential - PHI - All Users`), enable **Configure encryption**, republish
Wrong label order/priority	Labels created out of sensitivity order	Reorder `Public` → `Internal` → `Confidential - PHI` → `Highly Confidential - PHI Restricted`; order sets priority

B. Label encryption breaks a clinical app / blocks care access

• This is the healthcare-specific risk. If a **legacy EHR/PACS integration or clinical viewer** cannot open PHI-labeled content, **do not enforce encryption broadly** — this can impede continuity of care.

• Test the inventoried clinical apps (Requirement 2.6) on the pilot; if an app is incompatible, keep encryption in pilot, document the emergency ("break-glass") access approach, and involve clinical IT and the Privacy/Security Officer before expanding.

• For the `Highly Confidential - PHI Restricted` label, confirm the **named care-team group** actually contains the clinicians who need access (minimum-necessary must not become no-access).

C. PHI auto-labeling not labeling

• Confirm `Auto-Label - PHI Health Records - Pilot` is turned on (not left in simulation). Simulation reports matches but applies nothing — by design you review simulation first.

• Auto-labeling for SharePoint/OneDrive at rest requires the higher plan; verify licensing with `PHI-Discovery.ps1` and Requirement 2.1.

• Check the rule's health/PHI sensitive-information types and confidence — too high a confidence or instance count can suppress real PHI matches.

D. HIPAA DLP is too noisy (false positives)

• Expected before the audit gate — keep `DLP Policy - PHI HIPAA - Audit` in test/audit mode and tune. Raise the match confidence, require a higher instance count, and add exceptions for legitimate referral, billing, and care-coordination flows.

• Review matches in Purview → **Data Loss Prevention** → **Alerts** and **Activity explorer**; run `PHI-Report.ps1`.

• **Do not** switch to enforce until the noise is acceptable — erroneously blocking clinicians is a patient-care risk, not just a help desk ticket.

E. HIPAA DLP not blocking after enforce

Symptom	Cause	Remediation
Enforce policy does not block	Policy left in test mode, or scope excludes the user	Confirm `DLP Policy - PHI HIPAA - Enforce` mode is **Turn the policy on**; confirm the user/location is in scope

Symptom	Cause	Remediation
Endpoint (device) rules never fire	Device not onboarded to Purview	Onboard the device (Purview → **Settings** → **Device onboarding**); verify with `PHI-Discovery.ps1`
Teams/SharePoint PHI not covered	Location not enabled on the policy	Edit the policy and enable the missing location

F. Retention disposing too much or nothing

- **Over-disposal:** confirm the duration on `Retention Policy - Healthcare Baseline - Schedule-Defined`

and the end action; pilot on `Purview - PHI Pilot Users` before widening. Disposal is irreversible — and the duration must come from your **records schedule**, not a default.

- **Nothing retained:** confirm the policy shows **On** and is scoped to the correct locations; run

`PHI-Validation.ps1`.

- For clinical records, enable **disposition review** so PHI is reviewed before deletion rather than

auto-deleted. Keep the HIPAA-documentation 6-year label (`Retention Label - HIPAA Documentation - 6 Year`) distinct from the clinical-records label.

G. Retention duration uncertainty (which schedule?)

- Retention durations are a **records/legal determination — deferred**. If the correct medical-record

retention period is unknown, **do not guess**: leave the clinical label in pilot and obtain the schedule from your records/privacy/legal function (state law varies, often longer for minors). The solution implements the schedule; it does not decide it.

H. Licensing / feature missing

- Auto-labeling at rest, endpoint DLP, DSPM / DSPM for AI, insider risk, communication compliance, and

advanced records require Microsoft 365 E5 or the E5 Compliance add-on. If a feature is absent from the portal, verify the plan with `PHI-Discovery.ps1` and Requirement 2.1 — **verify your licensing/tenant** (availability evolves).

I. Diagnostics quick reference

```
# Security & Compliance PowerShell (Exchange Online Management module)
Connect-IPPSSession
Get-Label | Select-Object DisplayName, Priority, ContentType
Get-LabelPolicy | Select-Object Name, Enabled
Get-DlpCompliancePolicy | Select-Object Name, Mode, Enabled
Get-RetentionCompliancePolicy | Select-Object Name, Enabled, Mode
```

For PHI classification and DLP events, use the Purview **Activity explorer** and the unified audit log (Requirement 2.7).

J. When to escalate

If a PHI label policy is published and propagated, the user is in scope, licensing is correct, and labels still do not appear (or DLP still does not act) after 24 hours and a `PHI-Remediation.ps1` run, collect the output of `PHI-Discovery.ps1` and `PHI-Validation.ps1` and open a Microsoft support case. Route any regulatory, records, or legal question (retention schedule, records file plan, legal hold, insider-risk/communication-compliance case action) to your compliance, records, privacy, and legal functions — those determinations are **deferred**, not made here.

7. Best Practices — Microsoft Purview for Healthcare (HIPAA/PHI)

- **Keep the PHI taxonomy small.** Three to five labels clinicians and staff can actually reason about

beats a dozen nobody uses. Name each label plainly (`Confidential - PHI`, `Highly Confidential - PHI Restricted`) and give it a clear tooltip.

- **Apply minimum-necessary in the label permissions.** Scope `Highly Confidential - PHI Restricted`

to a **named care-team / role group**, not all users — the label's encryption permissions are where the HIPAA minimum-necessary principle becomes a technical control.

- **Pilot encryption against clinical apps first.** Label encryption can break legacy EHR/PACS

integrations and must never impede continuity of care. Test the inventoried clinical apps (Requirement 2.6) and agree emergency ("break-glass") access **before** enforcing encryption broadly.

- **Simulate PHI auto-labeling.** Always run `Auto-Label - PHI Health Records - Pilot` in simulation

and review matches before turning it on — it labels PHI at scale and mistakes are visible to users.

- **Audit DLP before you enforce.** The single most important practice: run every DLP policy in

test/audit, review matches, tune out false positives (referral, billing, care-coordination flows), and only then enforce. Erroneously blocking clinicians is a **patient-care risk**, not just a help desk ticket. Prefer **block-with-override** so a justified clinical action can proceed.

- **Tune with confidence levels and instance counts.** Reduce false positives by raising match

confidence and requiring a minimum count of PHI instances rather than a single hit.

- **Name every object by purpose and stage.** Use `<Purpose> - <Scope> - <Stage>` (rename

`DLP Policy - PHI HIPAA - Audit` to `... - Enforce` at the gate) so the portal shows exactly where each policy sits in its lifecycle — useful evidence in a HIPAA audit.

- **Set retention from the records schedule, never a guess.** Medical-record retention is a

records/legal determination (state law, often longer for minors). Implement the schedule your records/privacy function supplies; capture the source so the schedule is defensible. Keep the HIPAA-documentation 6-year retention (§164.316) distinct from clinical-record retention.

- **Use disposition review for PHI records.** Retention disposal is irreversible; route records to

disposition review so PHI is never auto-deleted unreviewed, and pilot on `Purview - PHI Pilot Users` before widening.

• **Keep insider-risk and communication-compliance strictly role-separated.** These are HR/privacy sensitive — apply privacy-by-design and pseudonymization where available, and **defer case outcomes to HR/legal**. This solution provides the technical method and evidence, not the determination.

• **Report coverage regularly and keep it as HIPAA evidence.** Track PHI labeled-item and DLP-event coverage with `PHI-Report.ps1`, chase gaps (unlabeled PHI locations, services with no DLP), and retain the reports as part of your compliance documentation.

• **Document the objects and the rollback.** Record the PHI taxonomy, policy names, scopes, the records-schedule source, and the rollback (revert DLP to audit; disable a retention policy) for repeatability and change control.

8. Deliverables Summary — Microsoft Purview for Healthcare (HIPAA/PHI)

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	What a Healthcare-tailored Purview program is — PHI labels, auto-labeling, DLP, retention/records — benefits, limitations, scope boundary
2. Requirements Guide	Every Healthcare/PHI prerequisite with Verify / Implement-if-missing
Global Requirements (Purview)	Category-wide Purview prerequisites, published once
3. Implementation Guide	Exact, ordered Purview portal steps (PHI labels, label policy, auto-labeling simulation, DLP audit-then-enforce, retention/records from your schedule, optional DSPM for AI)
5. Testing Guide	Validation procedures with pass/fail gates and the DLP audit gate (synthetic PHI only)
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations tuned for PHI and clinical continuity

PowerShell scripts

Script	What it does
`PHI-Discovery.ps1`	Reports the tenant's sensitivity labels, DLP policies, and retention config; flags DLP already enforcing, endpoint onboarding, and licensing signals
`PHI-Validation.ps1`	Confirms the expected PHI labels are published, the HIPAA DLP policy exists (reports mode), and the retention policy exists and is on
`PHI-Report.ps1`	PHI classification + DLP-event coverage summary across the enabled services (HIPAA evidence)
`PHI-Remediation.ps1`	Safe remediation of common gaps (default `-WhatIf`); enables a published-but-off label/retention policy — never auto-enforces DLP
`PHI-Set-ScopeTargeting.ps1`	Builds/updates the PHI pilot / care-team scope Entra security groups

All scripts are **read-only or `-WhatIf`/`-Apply`-gated by default**, use **Security & Compliance PowerShell** (`Connect-IPPSSession`) and/or **Microsoft Graph**, and contain **no credentials or secrets**.

What the buyer receives

- This implementation guide as a Word document and PDF.
- All five PowerShell scripts in a single ZIP.
- A repeatable process following the model: **Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand (enforce)**, with a DLP audit gate before enforce and a documented rollback.

Scope boundary (restated)

Regulatory, records-retention, and legal determinations — which data is a designated record set, how long medical records must be retained, records file plans, legal holds, and insider-risk / communication-compliance case actions — are **deferred to your compliance, records, privacy, and legal functions**. This solution provides the technical configuration method and the evidence, not the determination. Purview features are **licensing-/plan-dependent and evolving — verify your licensing/tenant**.

Outcome

PHI classified, protected, and retained with Microsoft Purview — a clear PHI label taxonomy with auto-labeling, HIPAA DLP tuned in audit before it enforces, and retention that meets your records schedule without over- or under-deleting — proven on a pilot before you scale, and defensible.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

PHI-Discovery.ps1

Purpose: Connects to Security & Compliance PowerShell and reports the tenant's current Microsoft Purview information-protection posture relevant to PHI: sensitivity labels and label policies, DLP policies (with mode: test/audit vs enforce, and whether the HIPAA/health template is in use), and retention labels/policies. This is the "what exists today" read used to plan the PHI taxonomy, the DLP audit gate, and the retention schedule. HOW TO RUN Install-Module ExchangeOnlineManagement -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\PHI-Discovery.ps1 Sign in as a Compliance Administrator (or Information Protection + DLP roles) when prompted. .EXAMPLE .\PHI-Discovery.ps1 Lists sensitivity labels, label policies, DLP policies (flagging any already enforcing), and retention labels/policies. PowerShell 5.1+/7+; uses Connect-IPPSSession. .NOTES Expected results: read-only inventory printed to the console; any DLP policy already in Enforce is flagged. No changes are made. White-label — no credentials in code. Purview is licensing-dependent and evolving — verify your licensing/tenant. > [CmdletBinding()] param()

How to run: Install-Module ExchangeOnlineManagement -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\PHI-Discovery.ps1 Sign in as a Compliance Administrator (or Information Protection + DLP roles) when prompted. .EXAMPLE .\PHI-Discovery.ps1 Lists sensitivity labels, label policies, DLP policies (flagging any already enforcing), and retention labels/policies. PowerShell 5.1+/7+; uses Connect-IPPSSession. .NOTES Expected results: read-only inventory printed to the console; any DLP policy already in Enforce is flagged. No changes are made. White-label — no credentials in code. Purview is licensing-dependent and evolving — verify your licensing/tenant. > [CmdletBinding()] param()

PHI-Remediation.ps1

Purpose: Remediates the low-risk gaps that PHI-Validation.ps1 finds — enabling a published-but-off PHI label policy and enabling a disabled healthcare retention policy — WITHOUT ever silently switching a DLP policy to enforce (that is the audit gate, a human decision, and blocking clinicians is a patient-care risk). Runs in -WhatIf by default; pass -Apply to make changes. It never deletes anything and never enables Enforce mode on DLP. HOW TO RUN Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\PHI-Remediation.ps1 Apply changes: powershell -ExecutionPolicy Bypass -File .\PHI-Remediation.ps1 -Apply Sign in as a Compliance Administrator when prompted. .EXAMPLE .\PHI-Remediation.ps1 -WhatIf Lists the proposed low-risk fixes without changing anything. Re-run with -Apply to make them. PowerShell 5.1+/7+; uses Connect-IPPSSession. .NOTES Expected results: a list of proposed actions (default) or applied changes (-Apply). DLP enforce is NEVER automated — the script only reports DLP policies still in test/audit for the operator to promote via Implementation Step 7. White-label — no credentials in code. > [CmdletBinding()] param([switch]$Apply, [string]$LabelPolicyName = 'Label Policy - Healthcare PHI Taxonomy - All Users', [string]$RetentionPolicyName = 'Retention Policy - Healthcare Baseline - Schedule-Defined') $WhatIf = -not $Apply $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'APPLY'})

How to run: Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\PHI-Remediation.ps1 Apply changes: powershell -ExecutionPolicy Bypass -File .\PHI-Remediation.ps1 -Apply Sign in as a Compliance Administrator when prompted. .EXAMPLE .\PHI-Remediation.ps1 -WhatIf Lists the proposed low-risk fixes without changing anything. Re-run with -Apply to make them. PowerShell 5.1+/7+; uses Connect-IPPSSession. .NOTES Expected results: a list of proposed actions (default) or applied changes

(-Apply). DLP enforce is NEVER automated — the script only reports DLP policies still in test/audit for the operator to promote via Implementation Step 7. White-label — no credentials in code. > [CmdletBinding()] param([switch]$Apply, [string]$LabelPolicyName = 'Label Policy - Healthcare PHI Taxonomy - All Users', [string]$RetentionPolicyName = 'Retention Policy - Healthcare Baseline - Schedule-Defined') $WhatIf = -not $Apply $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'APPLY'})

PHI-Report.ps1

Purpose: Summarizes PHI information-protection coverage so you can review the DLP audit gate and keep HIPAA evidence: (1) which sensitivity labels exist and their protection, (2) which services each DLP policy covers and its mode, and (3) recent DLP events from the unified audit log grouped by workload — the audit data you tune before enforcing. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PHI-Report.ps1 -Days 7 -CsvPath C:\Temp\phi-dlp.csv Sign in as a Compliance Administrator when prompted. Requires audit logging enabled (Requirement 2.7) for the DLP-event section to return data. .EXAMPLE .\PHI-Report.ps1 -Days 14 Prints a label inventory, a DLP location/mode matrix, and a per-workload count of DLP rule matches for the window, optionally exported to CSV. PowerShell 5.1+/7+; uses Connect-IPPSSession. .NOTES Expected results: read-only report to console (and CSV if -CsvPath); no changes are made. Keep the output as part of HIPAA documentation. White-label — no credentials in code. > [CmdletBinding()] param([int]$Days = 7, [string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\PHI-Report.ps1 -Days 7 -CsvPath C:\Temp\phi-dlp.csv Sign in as a Compliance Administrator when prompted. Requires audit logging enabled (Requirement 2.7) for the DLP-event section to return data. .EXAMPLE .\PHI-Report.ps1 -Days 14 Prints a label inventory, a DLP location/mode matrix, and a per-workload count of DLP rule matches for the window, optionally exported to CSV. PowerShell 5.1+/7+; uses Connect-IPPSSession. .NOTES Expected results: read-only report to console (and CSV if -CsvPath); no changes are made. Keep the output as part of HIPAA documentation. White-label — no credentials in code. > [CmdletBinding()] param([int]$Days = 7, [string]$CsvPath)

PHI-Set-ScopeTargeting.ps1

Purpose: Creates (or updates) the Microsoft Entra security group this Healthcare solution targets its PHI labels, DLP, and retention at — the pilot scope 'Purview - PHI Pilot Users' (and, optionally, a narrower care-team / role group for the PHI-restricted label per the minimum-necessary principle) — and adds the supplied members. Use it to stand up Requirement 2.5 before publishing any policy, and to widen scope during Expand. HOW TO RUN Install-Module Microsoft.Graph -Scope CurrentUser Preview: powershell -ExecutionPolicy Bypass -File .\PHI-Set-ScopeTargeting.ps1 -Members user1@contoso.com,user2@contoso.com -WhatIf Apply: powershell -ExecutionPolicy Bypass -File .\PHI-Set-ScopeTargeting.ps1 -Members user1@contoso.com,user2@contoso.com Sign in with rights to create groups (Groups Administrator) when prompted. .EXAMPLE .\PHI-Set-ScopeTargeting.ps1 -GroupName 'Purview - PHI Pilot Users' -Members clinician1@contoso.com -WhatIf Previews creating the pilot group and adding the member without changing anything. Remove -WhatIf to apply. PowerShell 5.1+/7+; uses Microsoft Graph (Connect-MgGraph). .NOTES Expected results: the group exists (created if missing) and the named members are added; -WhatIf previews without changing anything. White-label — no credentials in code. > [CmdletBinding(SupportsShouldProcess=$true)] param([string]$GroupName = 'Purview - PHI Pilot Users', [string[]]$Members = @())

How to run: Install-Module Microsoft.Graph -Scope CurrentUser Preview: powershell -ExecutionPolicy Bypass -File .\PHI-Set-ScopeTargeting.ps1 -Members user1@contoso.com,user2@contoso.com -WhatIf

Apply: powershell -ExecutionPolicy Bypass -File .\PHI-Set-ScopeTargeting.ps1 -Members user1@contoso.com,user2@contoso.com Sign in with rights to create groups (Groups Administrator) when prompted. .EXAMPLE .\PHI-Set-ScopeTargeting.ps1 -GroupName 'Purview - PHI Pilot Users' -Members clinician1@contoso.com -WhatIf Previews creating the pilot group and adding the member without changing anything. Remove -WhatIf to apply. PowerShell 5.1+/7+; uses Microsoft Graph (Connect-MgGraph). .NOTES Expected results: the group exists (created if missing) and the named members are added; -WhatIf previews without changing anything. White-label — no credentials in code. > [CmdletBinding(SupportsShouldProcess=$true)] param([string]$GroupName = 'Purview - PHI Pilot Users', [string[]]$Members = @())

PHI-Validation.ps1

Purpose: Verifies that the named objects this Healthcare solution deploys are present and in the expected state: the PHI sensitivity-label taxonomy is published, the HIPAA DLP policy exists (reporting its mode so you can see whether it has passed the audit gate into enforce), and the healthcare retention policy exists and is enabled. Pass/fail per the Testing Guide. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PHI-Validation.ps1 Sign in as a Compliance Administrator when prompted. Pass -DlpPolicyName / -RetentionPolicyName / -LabelPolicyName to match any renamed objects. .EXAMPLE .\PHI-Validation.ps1 Prints VALIDATION PASSED (exit 0) when the label policy is enabled, the HIPAA DLP policy is present, and the retention policy is enabled; GAPS FOUND (exit 1) otherwise. PowerShell 5.1+/7+; uses Connect-IPPSSession. .NOTES Expected results: pass/fail per object with exit code 0 (pass) or 1 (gap). Read-only, no changes. White-label — no credentials in code. > [CmdletBinding()] param([string]$LabelPolicyName = 'Label Policy - Healthcare PHI Taxonomy - All Users', [string]$DlpPolicyName = 'DLP Policy - PHI HIPAA', [string]$RetentionPolicyName = 'Retention Policy - Healthcare Baseline - Schedule-Defined')

How to run: powershell -ExecutionPolicy Bypass -File .\PHI-Validation.ps1 Sign in as a Compliance Administrator when prompted. Pass -DlpPolicyName / -RetentionPolicyName / -LabelPolicyName to match any renamed objects. .EXAMPLE .\PHI-Validation.ps1 Prints VALIDATION PASSED (exit 0) when the label policy is enabled, the HIPAA DLP policy is present, and the retention policy is enabled; GAPS FOUND (exit 1) otherwise. PowerShell 5.1+/7+; uses Connect-IPPSSession. .NOTES Expected results: pass/fail per object with exit code 0 (pass) or 1 (gap). Read-only, no changes. White-label — no credentials in code. > [CmdletBinding()] param([string]$LabelPolicyName = 'Label Policy - Healthcare PHI Taxonomy - All Users', [string]$DlpPolicyName = 'DLP Policy - PHI HIPAA', [string]$RetentionPolicyName = 'Retention Policy - Healthcare Baseline - Schedule-Defined')